

Nimbus Cloud Technologies

Vendor and Third-Party Risk Management Policy

Purpose

Nimbus Cloud Technologies relies on third-party vendors for infrastructure, software, and services. This policy ensures vendors are evaluated and monitored for the risk they introduce to company and customer data.

Vendor Risk Tiers

Vendors are classified as Tier 1 (access to customer data or production systems), Tier 2 (access to internal, non-customer data), or Tier 3 (no data access). The depth of the security review is proportional to the tier.

Onboarding Review

Tier 1 vendors must complete a security questionnaire, provide a current SOC 2 Type II report or equivalent, and sign a Data Processing Agreement before being granted access to any company system or data, consistent with the Data Privacy Policy.

Ongoing Monitoring

Tier 1 and Tier 2 vendors are reassessed annually, including a review of any security incidents the vendor has disclosed since the last review.

Access Controls

Vendor access to company systems is scoped to the minimum required, time-limited where practical, and logged. Vendor access is revoked immediately when a contract ends or a vendor relationship is terminated.

Offboarding

When a vendor relationship ends, the vendor must confirm in writing that all company and customer data has been returned or securely deleted, consistent with the Data Retention and Backup Policy.